TALLER APLICADO PARA CIBERSEGURIDAD

AIEP Los Ángeles – Ingeniería, Energía y Tecnología – Ingeniería en Ciberseguridad

Fecha:03-06-2025

AIEP de la Universidad Andrés Bello

Implementación del GRC en la Ciberseguridad

- Fundamentos previos: Triada CID y Funciones NIST

TRIADA DE SEGURIDAD: CID

- Confidencialidad
  - Solo personas autorizadas deben acceder a los datos.
    Ej: uso de contraseñas, cifrado de archivos.
- Integridad
  - Los datos deben ser correctos y no manipulados.
    Ej: registros de cambios, validaciones.
- Disponibilidad
  - Los datos y servicios deben estar operativos cuando se necesiten.
  - Ej: respaldos, servidores redundantes.

EJEMPLO PRÁCTICO CID

Plataforma de clases online

- **Confidencialidad: los exámenes solo los ve el profesor.**
- **Integridad: las notas no pueden ser modificadas sin registro.**
- **Disponibilidad: la plataforma debe funcionar en época de pruebas.**

FUNCIONES DE LA CIBERSEGURIDAD (NIST)

- **Identificar**
  - Saber qué tengo y qué debo proteger.
  - *Ej: inventario de equipos y sistemas.*
- **Proteger**
  - Poner barreras antes del problema.
  - *Ej: antivirus, control de acceso, firewalls.*
- **Detectar**
  - Saber si algo malo ocurre.
  - *Ej: alertas, monitoreo, registros de actividad.*
- **Responder**
  - Actuar si ocurre un incidente.
  - *Ej: protocolo de incidentes, cortar conexiones.*
- **Recuperar**
  - Volver a la normalidad tras el daño.
  - *Ej: restaurar respaldos, reparar servicios.*

EJEMPLO PRÁCTICO NIST

Empresa de ventas en línea

- Identifica sus servidores y sistemas de pago.
- Protege con doble autenticación.
- Detecta accesos no habituales.
- Responde bloqueando sesiones sospechosas.
- Recupera el sistema con respaldos diarios.

¿QUÉ ES GRC?

- GRC: Gobierno, Riesgo y Cumplimiento
  Es un sistema que organiza cómo se toman decisiones, se gestionan riesgos y se cumplen normas dentro de una organización.
- Gobierno → Define políticas y responsabilidades.
- Riesgo → Evalúa amenazas y planifica qué hacer.
- Cumplimiento → Asegura que se respeten las normas internas y externas.

¿PARA QUÉ SIRVE EL GRC?

- Mantiene actualizadas las políticas de seguridad.
- Permite actuar rápidamente frente a incidentes.
- Conecta los conceptos de CID y NIST en un sistema funcional.
- Ayuda a que la ciberseguridad no dependa de una sola persona.
- Aporta trazabilidad: todo lo que se hace, queda registrado

EJEMPLO SIMPLE DE GRC EN ACCIÓN

- Escenario: Colegio con sistema de notas online

Elemento	Ejemplo
Gobierno	Se exige doble autenticación para acceder al sistema.
Riesgo	Se evalúa la posibilidad de hackeo o filtración de notas.
Cumplimiento	Se sigue la Ley de Protección de Datos.

- Confidencialidad: Las notas están protegidas.
- Integridad: Nadie puede cambiar notas sin registro.
- Disponibilidad: La plataforma debe estar activa todo el año.
- NIST aplicado: Identificar (sistema de notas), Proteger (acceso), Detectar (monitoreo), Responder (bloqueo), Recuperar (respaldo).

GRC COMO ESTRUCTURA VIVA

- “El GRC es como un depósito organizado donde se guardan y mantienen actualizadas las políticas, evaluaciones de riesgos y reglas internas de una organización.”
- Permite una visión centralizada y adaptable.

- Actúa como base para auditar, mejorar y evolucionar la seguridad.

- Sin GRC, las acciones de seguridad se vuelven aisladas y reactivas.

ACTIVIDAD EN GRUPOS

1. Formar grupos de 3 a 5 personas.

2. Elegir una organización (real o ficticia).

3. Completar esta tabla:

Elemento	¿Qué harían ustedes?
Gobierno	¿Qué política aplicarían?
Riesgo	¿Qué amenazas anticipan?
Cumplimiento	¿Qué norma seguirían?
Protección CID	¿Confidencialidad, Integridad o Disponibilidad?
Función NIST	¿Identificar, Proteger, Detectar, etc.?

4. Exponen en 20 minutos su caso aplicado.

AIEP
de la Universidad Andrés Bello